

James Stallkamp

Bram Lewis

CS 373

08/04/2024

Module 6 Write Up

Contents

Introduction	1
Protection Strategies	1
Network Security Technologies	4
MITM.....	4
Threats	5
Conclusion.....	6
Appendix	6

Introduction

Network Security is a hugely complex topic in of itself and involves many different topics, the question is why we bother with this if we can work to remove or detect viruses on the system. The idea is that network security is important because it can prevent attackers from infecting machines in the first place. However, there are other important considerations, such as the network itself can be compromised and used such as a bot net or DDOS (distributed denial of services).

First, we discussed some of basics of network principles and some of the ideas that first started the internet. One concept was the Robustness principle “Be liberal in what you accept and conservative in what you send” not forcing people to adhere so strictly to specs. This idea is largely what allowed the internet to become the modern version that it is. Essentially it allowed for software to work on much looser specs so that network software did not have to be bespoke to the hardware it was originally written on. This idea is fundamental to the modern internet because internet is so powerful because of how easy it is to scale and add more machines. If modern devices could only communicate with other proprietary devices, then clearly this would make scaling the internet radically more difficult. However, as was described in lecture this also opens a lot of vulnerabilities because there could be old standards hidden in the system code.

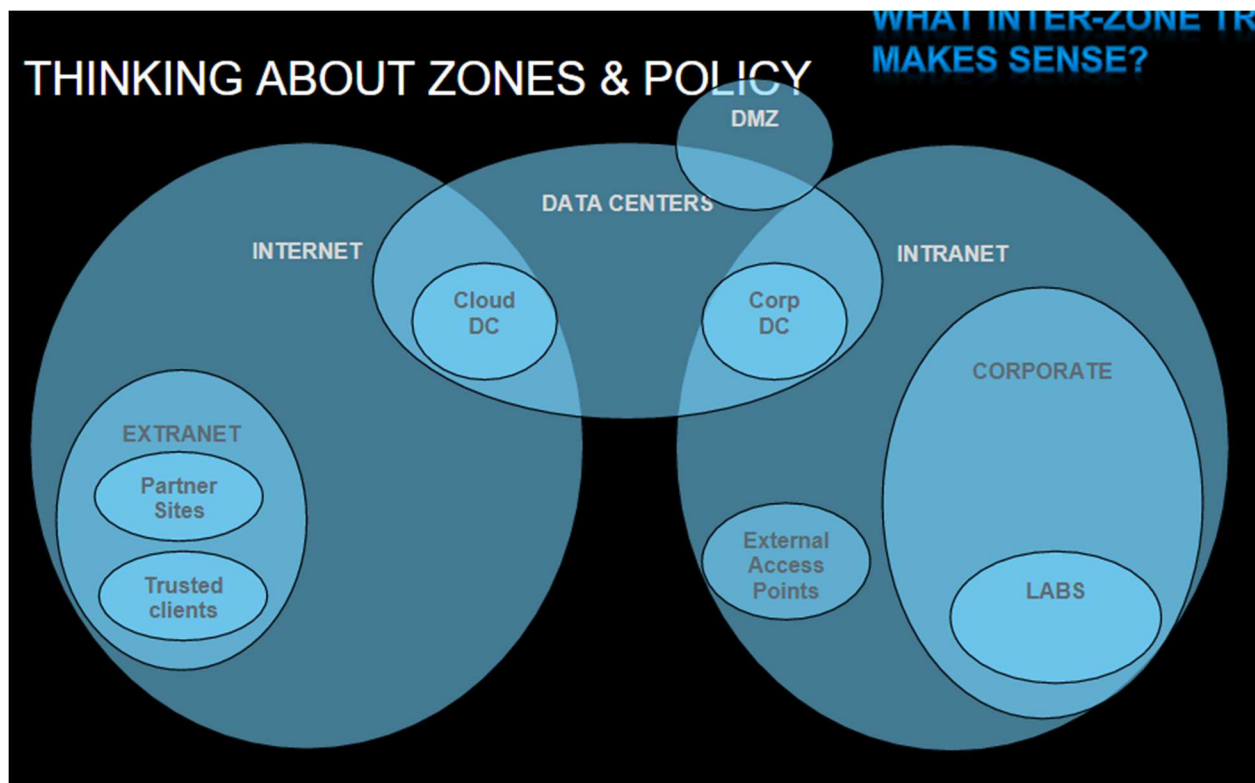
Protection Strategies

- Positive policy, these are whitelists where known connections are whitelisted or accepted into the network.

- Firewalls, a machine to look at network activity and determine if it is valid based on what it is doing and to where, IE shell commands to a web server would be noticed and blocked.
- Defense in depth
- Intrusion detection
- Honey nets / Intrusion Deception
- Quarantine
- Reputation

Attack surface, the set of operations that a network responds to and thus are potentially vulnerable. We can disable certain features or connections to decrease the attack surface.

Zones and Policy: Another tactic to protect networks is to create zones where machines are separated and network traffic between the zones can be monitored and controlled. The area known as the DMZ can be used to control all traffic into and out of the greater network. The theme here seems to be creating layers of protection like a castle or series of trenches.



Web gateway and email gateway both act-like proxies where they sit in between machines and the outside connections so that information can be stored and analyzed before being delivered. Web gateways filter information coming from webpages and could block specific data like ads. Emails gateways work similarly but filtering email track to again remove specific data like unwanted attachments or emails from known bad senders. These gateways act much like their name and act as a gate for incoming data to protect the network. These are the first line of defense in a system known as a

defense in depth, which is a modern security strategy. The idea is these gateways act like the first line of defense but then we have more layers of protection like firewalls and other active network monitoring tools.

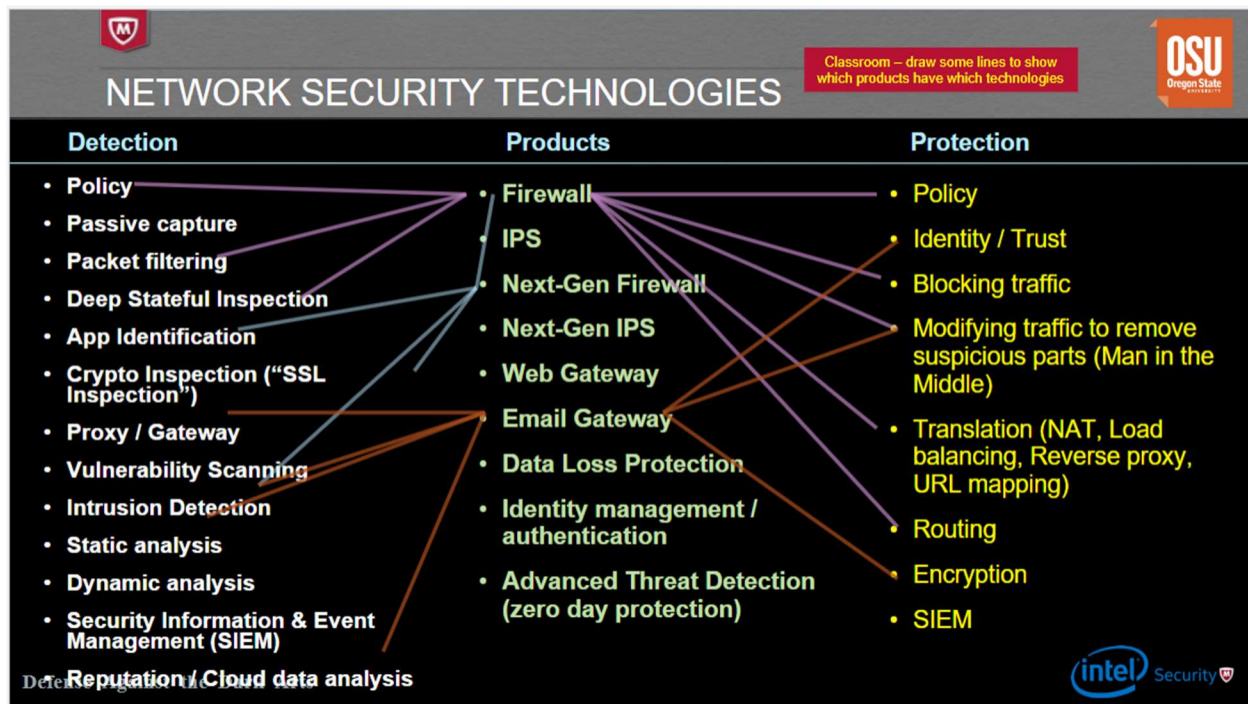
Firewall vs intrusion protection system. Intrusion protection systems are looking for things you don't want to happen vs firewalls are looking for things that you do. IPS systems monitor for known attacks and specifically works well only on known attacks. An IPS is useful for protecting against known exploits on software that might be running in places you are not aware of, such as old operating systems in point of sales terminals. The downside to an IPS is that it does not prevent unknown or zero-day attacks because it can't identify them. While this vulnerability is dangerous it only highlights the need for a defense in depth strategy so that we have other mechanisms in place to protect against zero-day attacks. The last downside to an IPS is the chance of a false positive where our software incorrectly flags activity as dangerous when it is normal activity.

Honeynet, is the concept of putting out a decoy system that is meant to be attacked. Honeynets usually contain enough fake information to appear real but then somehow work against the attackers. Honeynets can do things like re-route traffic, slow down traffic, or giving away fake information that can be used to track or identify attackers. I was very sad to hear that these are not more used because I like the idea of doing more proactive measures to stop attackers. One of reoccurring themes in this class has been responding to attackers after they were initially successful, honeynets seem like a way to prevent or circumvent new attacks entirely.

Quarantine: Idea is to place hosts that misbehave into quarantine area, so others are not infected.

Reputation: Online list of good and bad known actors, at some point activity from a known actor is refused if their reputation goes low enough. This would apply to specific addresses or websites that are known for being malicious. These seems fragile and not very effective because we rely on someone to maintain them, and we assume we trust them.

Network Security Technologies



These various detection and protection ideas get combined into specific products to help provide network security. For example a firewall needs to have both detection and protection methods, the reoccurring idea is that we need many different methods to identify and stop malicious behavior. The idea here is to help us identify what kind of methods or concepts are being used in specific products.

MITM

Main in the middle concept can be used for good or bad. The man in the middle idea can intercept data packets and not only see but also change the data. This could easily be used for both good and bad because one could change the data to be something malicious, but it could also be used to notice that the data itself is malicious. It seems like many of the tools used to secure systems also have the ability to compromise them like we saw with rootKits. Some examples of how attackers can use MITM is ARP poisoning or TCP hijacking. ARP poisoning is the idea of manipulating network records and TCP hijacking is changing data in packets, both are trying to reroute or change traffic to something malicious. Some good examples of MITM are terminating TCP proxy or acting like a HTTP proxy, these allow good actors to detect and correct attackers when they try to attack a TCP stack.

We detect MITM using a HMAC, an HMAC is a one-way function that is almost impossible to invert. HMACs can be used to detect MITM because we attach the HMAC to the data and use it as an identifier to prove that the data has not been modified from the original sender. These identifiers seem like a great solution, but it was pointed out in lecture that we have had to change the HMACs that we use because eventually they can be broken.

The n^2 problem is the idea that one needs n^2 shared secrets to have secure communications. The solution to this is public key cryptography where there is a shared and public key that allows for less

shared secrets. The public key is known to everyone and can be used to lock or secure data then each person has a private key that is used to secure data so that only the person with the key is able to unlock it. These are the basis for how we process modern day financial transactions.

SSL/TLS putting this all together when you connect to a website there are a series of handshakes to establish connection including sending of standards, certificates, and actual data. This guarantees a bunch of security features such as the following:

TLS/SSL GUARANTEES	
1. The host you connect to has the private key of the server certificate	
2. The DNS name of this host, stored in the server certificate (CN=) resolves to the same IP address that you connected to	
3. The connection is as hard to decrypt as the ciphersuite selected, given that the random numbers in use are cryptographically strong (i.e., impossible to predict)	
4. The integrity of the data is guaranteed by as strong a hash as specified in the ciphersuite selected	
5. The connection cannot be decrypted later if the server is compromised, <i>ONLY IF</i> the ciphersuite with perfect forward secrecy (PFS)	RSA does NOT have PFS
6. The client is guaranteed to own the secret key of the client certificate, if a client certificate is in use (←approximately never)	Note that Client Certs are almost NEVER used
7. The client DNS, stored in the client certificate resolves to the same IP address seen by the server (if there is a client certificate)	

However, these could be tampered with but modifying network device files or modifying packet information.

Threats

Recon is a form of attack and is where the attacker does things to gather information about a network that can be used to later attack it. Recon itself can seem benign, but successful recon can mean the difference between a virus being delivered to a vulnerable system vs being stopped at the DMZ. Recon can be both active or passive and is when the attacker is listening to traffic as opposed to scanning it and taking information. Active recon can be detected in some ways by looking at network traffic, however if scanning is done in an “intelligent” way it becomes extremely difficult to detect. NMAP is a tool that can be used to scan networks and get information on the connections.

Spoofing: Attackers can masquerade as another network entity in order to gain advantage over network defenses. Example was the LAND attack, which was a DOS attack that essentially looped traffic back and forth between the same points to eventually kill the network stack. Things that can be spoofed include, TCP sequence numbers, IP addresses, mac addresses, email addresses, and HTTP fields.

Defending against spoofing, the basic idea is to prove that a source is who it actually claims to be and that the data has not been modified. One method is reverse path filtering where a system would

replicate how it would send the original message if it were asked to, this could then be used to investigate if the route the original message took makes sense or seems “good”

DOS or resource consumption attacks. These attacks consume network resources with the purpose of degrading a service or making it unusable. These attacks do not usually involve stealing data like previous attacks we discussed. So why do people do these attacks? Usually, it is for hacktivism or sending some kind of message by disrupting the services provided by a state or group. DOS attacks can be many forms such as network exhaustion, CPU exhaustion, memory exhaustion, storage exhaustion, or application vulnerabilities. DDOS is disturbed DOS attacks and involves using many internet connected devices to perform a coordinated DOS attack on a singular site from many bots. DDOS attacks are becoming more common specifically because of internet of things devices, when fridges and coffee makers have computers in them that can also become bots.

DOS defenses include things like network traffic validation and scrubbing centers like Cloudflare. These mechanisms work by analyzing traffic and trying to determine if it is valid or to extract only the good data and pass it onto the destination.

Bugs and back doors, both result in attackers finding attack avenues that allowed them to infect devices. Routers are an example of devices that are turned into bots because often users leave the default password in place and attackers can easily take control.

Packet Filtering is the concept of intercepting incoming packets and doing something with them. Within packet filtering there is stateful filtering where we keep track of the last known status and stateless which is just applying policies.

Proxying has transparent and non-transparent filters, transparent is where the proxy is not apparent vs none where you can tell from the headers that it has been rerouted. MITM are an example of proxies that we discussed earlier.

NAT: Because there are not enough IPv4 addresses for all devices we create NATs to create hierarchies in our networks so that we can communicate with many devices at once. Then one endpoint can have one IP address but act as a communication port for many devices connected to it.

Conclusion

In conclusion this module looked at various network threats and security concepts. Network security is slightly different from traditional security on specific systems, but many of the themes are similar. The ideas focus on identifying suspicious behavior, creating patterns to recognize behavior, and relying on many layers of security to overcome weaknesses. Network security is probably one of the more important fields of cybersecurity simply because of how many internet connected devices we are creating. Network security is also very important because in theory if we perfected network security then traditional malware would be extremely difficult to spread. In the appendix you will find my attempt at the firewall policy homework.

Appendix

This write-up follows the MLA standard for expository essays.

#	Source	Destination	Service	Action	Alert	Comment
1	Intranet	Internet	(HTTP & TCP/80) (HTTPS & TCP/443)	Permit	No	Everyone on the Intranet is allowed to browse the Internet
2	Intranet	???	DNS & UDP/53		No	How do you think DNS should work from the Intranet out?
3	Intranet	Internet	SMB	Deny	Yes	Do not allow file browsing over the internet, alert so we can catch the sucker.
4	Corp DC	Cloud DC	FTP	Permit	No	Connect the data centers (Corp DC, Cloud DC)
5	Cloud DC	Corp DC	FTP	Permit	No	Connect the data centers (Corp DC, Cloud DC)
6	Intranet	DCs	SMB	permit	No	Enable corporate workstations to share files with the DCs
7	Internet	Intranet	HTTPS	permit	No	Enable traffic into the DMZ web server
8	Intranet	CORP DC	SMTP			Enable the DMZ mail server
9	Intranet	Cloud DC	SMTP			Enable the DMZ mail server
10	Partner 1 on Internet	?	HTTPS	?	?	?
11	Trusted client	?	HTTPS	?		?

	on Internet					
12	Internet	Corp Labs	HTTPS	Deny	Yes	Protect lab servers from Internet traffic
13	Corp DC	Corp Labs	SSH	Permit	No	Enable corporate users to access the lab machines
14	Intranet	Extranet supplier 7	HTTPS	Permit	No	Access an extranet partner
15	DC Corp	internet	SSH	Permit	Yes	Backup servers
16	Cloud Corp	internet	SSH	Permit	Yes	Backup servers
17	Intranet	Cloud DC	RemoteDesktop	Permit	Yes	Remote desktops for corporate users
18	Internet	Cloud DC	RemoteDesktop	Permit	Yes	Allow users to connect to their desktops from home
19	Internet	Corp DC	VMWare control	Permit	Yes	Allow users to connect to their desktops from home
20	Internet	Corporate Web Server	HTTPS	Deny	Yes	Internet users can browse corporate web server
21	intranet	Corporate Web Server	SSH	Permit	Yes	Local admins can maintain the corporate web server
22	intranet	Corporate Web Server	HTTPS	Permit	Yes	Intranet users can access

						corporate web server
23	Email Server	Corp users	SMTP	Permit	Yes	Corporate users can read their mail
24	Corp Users	Email Server	SMTP	Permit	Yes	Corporate users can send mail
25	?	Corporate DNS server				DNS server rules
26	?	Corporate DNS server				DNS server rules
27	?	Corporate DNS server				DNS server rules
28						
29						
30						
40	ANY	ANY	ALL	DENY	NO	Firewall policy is best done with a deny all rule at the bottom.